

STANDARD OPERATING PROCEDURE

SMR Cashflow Dashboard

What every screen is, who uses it and why, where its data comes from, and exactly where the system stands against HIPAA — with the parts that are still open stated plainly.

CLIENT	SYSTEM	VERSION	DATE
Sports Med Recovery	cfovaani.in	1.0	18 July 2026

Compliance status: technically sound, not yet compliant

All 13 automated technical controls pass in production. HIPAA is not met overall because no Business Associate Agreement has been signed with Supabase, Vercel or Striven, no Security Officer is named in writing, and no workforce training has been delivered. Details in sections 5 and 6.

01 Purpose & scope

The SMR Cashflow Dashboard is a read-and-post financial console over Sports Med Recovery's Striven ERP. It answers four questions the ERP makes slow to answer: **what are we owed, what do we owe, what is moving, and what is stuck** — and it posts approved invoices into QuickBooks Online without re-keying.

ITEM	DETAIL
Who uses it	Practice owner, finance/admin staff, and the external accountant. Three named accounts today.
System of record	Striven ERP. The dashboard never becomes the source of truth — it reads, shapes and posts.
Refresh	Cached in Supabase, refreshed automatically every 6 hours; each screen also has a manual refresh.
Out of scope	Clinical notes, diagnoses, imaging, insurance IDs, dates of birth, addresses. The dashboard must not be extended to carry these without a fresh risk analysis.

The one design rule behind everything

No patient name ever leaves Striven. Every screen, every export and every record posted to QuickBooks refers to a patient as PT-418 — a reference built from their Striven customer id. Staff who need the actual name look it up in Striven, where access is already controlled.

02 Getting in — access procedure

STEP	WHAT HAPPENS
1. Open	Go to <code>https://cfovaani.in</code> from a bookmark — never from a link in an email.
2. Log in	Your own username and password. Accounts are personal; sharing one is prohibited.
3. Session	Lasts 12 hours. Lock your screen whenever you step away.
4. Log out	Use Log out on a shared or unfamiliar device.

Rules that are enforced by the system, not just written down

CONTROL	BEHAVIOUR
Password storage	script-hashed. Even with database access, passwords cannot be read.
Failed attempts	5 wrong passwords in 15 minutes locks that account for 15 minutes.
Identity	Each session token is signed and names one user. There is no shared login.
Audit	Every login and every read of patient-derived data is recorded with user, page, IP and time.
Failure mode	If the user directory is unreachable the gate refuses everyone rather than falling back to a weaker credential.

Adding or removing a user

1. The Security Officer approves in writing, naming the person and the business reason.
2. The maintainer adds a row to `dashboard_users` with a hashed password — never plaintext.
3. The password is delivered out-of-band; the user completes training before first login.
4. **On departure:** delete the row the same day. To kill a live session immediately, rotate `SESSION_SECRET` — this logs everyone out and is the correct move for any non-amicable exit.

03 The nine screens — what each is for

Left sidebar, top to bottom. "Patient data" below means data derived from a patient's orders shown against a PT-reference — never a name.

1 Overview

Patient data (referenced)

WHAT	Executive summary — cash position, revenue and expense trend, AR and AP headlines, the invoices and bills that need attention now.
USE CASE	The Monday-morning screen. Owner opens it to see whether cash is moving and what is overdue, without opening anything else.
SOURCE	/api/status , /api/trends , /api/ar , /api/ap
HIPAA	Invoice rows show a PT- reference and the payer (a law firm, VA or TriCare). No names.

2 AR / AP

Patient data (referenced)

WHAT	Two sub-views. Receivables — every open invoice, aged current / 1–30 / 31–60 / 61–90 / 90+, with unapplied credits and voided amounts separated out. Payables — the same for supplier bills.
USE CASE	Collections and payment runs. "Who do we chase this week, and what must we pay before it goes overdue."
SOURCE	/api/ar , /api/ap
HIPAA	Highest-density patient screen. Invoice amounts and dates against PT- references — pseudonymised PHI, correctly handled.

3 P&L

No patient identifiers

WHAT	Revenue, expenses and net profit by period, broken down by account.
USE CASE	Month-end review and the accountant's starting point. Answers "did we make money, and where did it go."
SOURCE	/api/pl
HIPAA	Aggregate financial totals only — nothing traceable to an individual.

4 Orders

Patient data (referenced)

WHAT	Two sub-views. Orders — every sales order with type (PI / VA / TriCare), sales rep, payer, value and whether it has been invoiced. Tracking — the order chain, following each sales order through to its purchase orders and invoices.
USE CASE	Revenue leakage. An order that was delivered but never invoiced is money already spent and never billed — this is where it surfaces.
SOURCE	/api/orders , /api/so , /api/po
HIPAA	Order rows carry a PT- reference. The Sales Rep and Payer columns hold business names — a rep or a law firm — which are not PHI. This was checked: 16 distinct rep values and 64 distinct payers, none matching a patient.

5 Vendors & Items

No patient data

WHAT	Two sub-views. Vendors — supplier list with spend and payment terms. Catalog — the item/product master.
USE CASE	Purchasing and negotiation. "How much do we spend with this supplier, and on what."
SOURCE	<code>/api/vendors</code> , <code>/api/items</code>
HIPAA	Purely commercial data. Out of scope.

6 Accounts

No patient identifiers

WHAT	Chart of accounts with balances, plus customer payments received and bill payments made.
USE CASE	Reconciliation — matching what the ledger says against what actually moved.
SOURCE	<code>/api/accounts</code> , <code>/api/payments</code> , <code>/api/billpayments</code>
HIPAA	Ledger-level. Payments carry references, not names.

7 Exceptions

Patient data (referenced)

WHAT	Everything that does not add up, grouped: orders with no invoice, purchase orders with no matching sales order, unapplied credits, amount mismatches. Each group opens into the underlying rows.
USE CASE	The clean-up worklist. This is the screen that finds money — e.g. 25 unlinked purchase orders worth roughly \$50,494 currently sit here awaiting review.
SOURCE	<code>/api/exceptions</code>
HIPAA	Drill-down rows show PT– references.

8 Reports

PHI — handle exports carefully

WHAT	Two sub-views. Vendor purchases — what we buy from each supplier, built from purchase orders. Patient orders — what each patient reference orders, built from sales orders, ranked by order count. Cancelled orders are excluded from both. CSV export available.
USE CASE	Buying patterns and supplier negotiation on one side; product demand by patient cohort on the other.
SOURCE	<code>/api/reports/vendor-items</code> , <code>/api/reports/patient-items</code>
HIPAA	The most sensitive screen. A patient reference tied to specific medical items is health information. On-screen it is safe; an exported CSV must be treated as PHI — encrypted device only, never emailed out, deleted when the task is done.

9 QuickBooks

Posts references only

WHAT	Four numbered steps — Customers, Vendors, Items, Invoices — each showing exactly what exists in Striven but not yet in QuickBooks, with the option to create missing records individually, in a selection, or all at once. Invoices preview before posting.
USE CASE	Removes double data entry between Striven and the accounts, and keeps the two reconciled.
SOURCE	<code>/api/qb/*</code> (OAuth 2.0 to QuickBooks Online)
HIPAA	Intuit will not sign a BAA, so the design keeps PHI out entirely: customers are created as PT– references, and each invoice carries the reference, the original date and the amount — no name, no clinical detail. Verified: all 8 QuickBooks customers are references.

04 Procedure: posting to QuickBooks

Run in order. Each step only shows what is genuinely missing, so a step with nothing listed is already reconciled and can be skipped.

STEP	ACTION	WHY THE ORDER MATTERS
1 • Customers	Review the list of Striven customers missing from QuickBooks. Create all, or tick a selection.	An invoice cannot post without its customer. Created as PT– references.
2 • Vendors	Same, for suppliers.	Needed before any bill or purchase-side record.
3 • Items	Same, for products and services.	Invoice lines reference items; missing items fail the post.
4 • Invoices	Filter Pending / Posted / All. Preview an invoice, confirm, then post — singly, as a selection, or all pending.	Final step, once the three above are clean.

Two behaviours worth knowing

- **Dates are preserved.** A posted invoice carries its *original* Striven date, not the date you clicked post — so the accounts stay in the correct period.
- **Nothing posts twice.** Posted invoices are tracked, so re-running a batch skips what is already in QuickBooks.

Never do this

Do not send a patient name, date of birth, address, phone, email, diagnosis or any clinical description to QuickBooks — no matter how convenient a future feature makes it. Intuit is not covered by a BAA, so anything sent there is an unprotected disclosure.

05 HIPAA compliance — where this actually stands

What HIPAA asks for, and what is in place

REQUIREMENT	STATUS	EVIDENCE
Unique user identification §164.312(a)(2)(i)	Met	Per-user signed session tokens; the former shared token was removed
Password protection §164.312(a)(2)(iv)	Met	bcrypt hashes; no plaintext copy in code, env, Vault or config
Audit controls §164.312(b)	Met	login_events and phi_access_events record who read what, when
Minimum necessary §164.502(b)	Met	Names stripped at every write; only references reach the browser
Transmission security §164.312(e)(1)	Met	TLS enforced; session cookies HttpOnly + Secure
Log-in monitoring §164.308(a)(5)(ii)(C)	Met	Lockout after 5 failures in 15 minutes
Policies & procedures §164.316(a)	Written	Eight documents in docs/hipaa/
Risk analysis §164.308(a)(1)(ii)(A)	Written	21 risks rated, with owners and target dates
Business Associate Agreements §164.308(b)(1)	NOT MET	None signed with Supabase, Vercel or Striven
Workforce training §164.308(a)(5)	NOT MET	Material written; not delivered, register unsigned
Security Officer assigned §164.308(a)(2)	NOT MET	Not named in writing
Multi-factor authentication (not mandated, expected)	Gap	Not implemented — a stolen password alone reaches the data

An important distinction: PT-418 is not "anonymous"

Replacing names with references is **pseudonymisation**, not de-identification. Because SMR keeps the key in Striven, the order history and amounts stored against PT-418 remain protected health information under §164.514(b). This matters practically: it means Supabase and Vercel are still Business Associates and still need BAAs. What the references genuinely achieve is a much smaller blast radius if anything leaks, and keeping Intuit out of the PHI chain entirely.

06 Procedure: verifying compliance monthly

Step 1 — run the automated check

```
$ node scripts/hipaa-check.mjs

PASS A1 Passwords are hashed, never plaintext
PASS A3 Unauthenticated requests are refused
PASS A4 A forged session token is rejected
PASS A6 Brute force is locked out
PASS A7 Session cookies are HttpOnly + Secure
PASS B2 Every read of patient data is attributed to a user
PASS C1 No patient name is stored in the Supabase cache
PASS C3 QuickBooks holds no patient name
PASS D1 Site is served over TLS only
```

Technical controls: **13/13 PASS**

Safe to run any time — read-only, and the lockout test uses a throwaway username so it can never lock a colleague out. A failure prints the exact JSON path of the problem. **Do not silence a failure by adding it to the allowlist** — justify it in writing first.

Step 2 — review the audit logs (a human must do this)

```
-- failed logins in the last 30 days
select username, ip, at from login_events
where success = false and at > now() - interval '30 days' order by at desc;

-- who read patient data, and how much
select username, count(*), min(at), max(at) from phi_access_events
where at > now() - interval '30 days' group by username order by 2 desc;
```

Look for logins by departed staff, unfamiliar locations, bursts of failures, or a volume far outside someone's normal pattern. **Record that the review happened** even when nothing was found — the record is the deliverable, not the reassurance.

Step 3 — tick the manual items

BAAs signed · training register current · user list matches actual staff · risk analysis reviewed within 12 months · Security Officer named. A script cannot check any of these, and they are what an auditor asks for first.

Also re-run the check before shipping any change that...

- touches login, sessions or cookies
- adds a new cached dataset, or a new field to an existing one
- changes anything posted to QuickBooks
- adds any new external service — which needs its BAA signed *first*

07 Daily rules for everyone with a login

DO	DO NOT
Log in only from an encrypted work device with a screen lock	Log in from a public, shared or hotel computer
Use a unique password of 12+ characters	Reuse a password from email or banking
Refer to patients by their PT- reference in email and chat	Share your login — every action is recorded against your name
Delete CSV exports as soon as the task is finished	Email or upload an export outside SMR
Report anything odd the same day	Paste dashboard data into ChatGPT, Claude or any unapproved online tool
Reach the site from your bookmark	Look up a patient, friend or colleague out of curiosity — every read is logged

If something goes wrong

Tell the Security Officer **the same day** — a lost device, a shared password, an export sent somewhere it should not have gone, a name appearing where a reference should be, or a login you do not recognise. Do not wait until you are sure it was real; fast reporting is what turns a breach into a near-miss. There is no penalty for reporting in good faith.

Full procedure: [docs/hipaa/03-incident-response-plan.md](#) . **The contact details in that plan are still blank and must be filled in.**

08 Open items — what closes the gap

#	ACTION	PRIORITY	NOTE
1	Sign BAAs with Supabase, Vercel and Striven	Critical	Supabase needs the Team plan + HIPAA add-on; Vercel offers one to Pro teams via a HIPAA add-on; Striven is a direct request — a ready-to-send email is in 07-baa-action-pack.md
2	Name the Security & Privacy Officer in writing	Critical	Fill the blanks in 01-policies-and-procedures.md and the incident plan
3	Deliver training; sign the register	Critical	~20 minutes per person; material is written
4	Delete APP_USERS and ACCESS_PASSWORD from Vercel	Housekeeping	Severity already reduced — the code ignores them and all three passwords were rotated on 18 Jul 2026, so the stored values are dead
5	Add multi-factor authentication	90 days	The largest remaining technical weakness — logout does nothing against a correct stolen password
6	Start the monthly audit review	Monthly	First one due August 2026
7	Test a backup restore once; document the result	90 days	§164.308(a)(7) expects a contingency plan that has actually been exercised
8	Rotate the Supabase service key and access token	30 days	Both were exposed in a chat session. Must be done in the same sitting as item 4 — rotating without updating Vercel takes production down instantly

Summary in one paragraph

The software side is done and, unusually, it is *verifiable* — one command re-proves all 13 technical controls, so drift gets caught instead of assumed away. The remaining gap is organisational: three signatures, one appointment and one training session. None of it is engineering work, and all of it is achievable in a week. Until then the honest position is that the dashboard is built to HIPAA's technical standard but SMR is not yet HIPAA compliant.

Prepared by the system maintainer with AI assistance. This document is a factual record of the system as built and verified on 18 July 2026 — it is not legal advice and it is not a certification. A qualified HIPAA compliance professional should review it before it is relied upon in an audit, a payer contract or a breach response.